STRIDE аналіз СУМЗ

Домашнє завдання 2
Виконав: Задорожняк Ігор
Проєкт: MedRecordsManager

1 Назва та призначення проєкту
MedRecordsManager - система управління медичними записами приватної клініки. Через вебінтерфейс і мобільний застосунок вона надає доступ до історій хвороб, результатів аналізів та консультацій. Мета роботи - виявити загрози для API, бази даних і сервісу експорту та визначити пріоритетні захисти.
Це навчальна модель: наведені сценарії є можливими загрозами, а не результатами перевірки реальної системи. Найважливіші напрями захисту - контроль доступу до кожного запису, цілісність клінічних даних і можливість відновити роботу після інциденту.

2 Архітектура та потоки даних
Пацієнт переглядає й експортує власні записи. Лікар читає та змінює записи лише пацієнтів, до яких має обґрунтований доступ. Адміністратор керує користувачами та налаштуваннями; ця роль не повинна автоматично надавати доступ до змісту всіх медичних записів.

Компонент	**Призначення та потік даних**
Веб і мобільний клієнт	Надсилає через HTTPS облікові дані, запити на перегляд, зміну або експорт. Отримує лише дозволені дані. Адмінпанель використовує те саме API.
API та автентифікація	Перевіряє сесію, роль, зв’язок користувача з пацієнтом і дозволені поля. Читає або змінює БД; повертає результат клієнту.
База даних	Зберігає медичні записи, користувачів і права. Доступна лише дозволеним серверним компонентам. Резервні копії зберігаються окремо.
Сервіс експорту	Отримує від API завдання з ID запису та ініціатора через чергу. Повторно перевіряє актуальні права, отримує потрібні дані й формує PDF у приватному сховищі.
Доставка та аудит	Зовнішній e-mail провайдер надсилає повідомлення з посиланням без діагнозів у листі. Завантаження потребує входу та перевірки прав. API і сервіс експорту пишуть події в окремий журнал аудиту.

Межі довіри: пристрій користувача ↔ API; API ↔ БД; API ↔ черга та сервіс експорту; внутрішня система ↔ e-mail провайдер і одержувач. На кожній межі потрібні перевірка ідентичності, дозволів і вхідних даних. Інших зовнішніх інтеграцій у моделі немає.

3 STRIDE аналіз API

Об’єкт: API доступу до медичних записів. Розглядаю автентифікацію, читання, зміну даних та адміністративні операції. Категорії STRIDE використовую за визначеннями Microsoft [1].

Кат.	Загроза	Як проявляється	Захист
S	Підміна особи	Зловмисник використовує викрадений пароль або токен лікаря й надсилає запити від його імені.	MFA для персоналу; короткі сесії, відкликання сесій після компрометації; захищене зберігання токенів; перевірка підпису, строку та адресата токена.
T	Несанкціонована зміна запису	Пацієнт додає до запиту оновлення профілю поля diagnosis або doctor_id; сервер приймає їх без перевірки.	Дозволений перелік полів для кожної операції; перевірка прав на запис і поле; валідація; контроль версій для запобігання втраті паралельних змін.
R	Заперечення виконаних дій	Лікар заперечує видалення призначення, а журнал містить лише IP-адресу без ID користувача й запису.	Індивідуальні акаунти; аудит хто, коли, що і з яким результатом зробив; ID запиту та версії запису; окреме захищене сховище журналів і синхронізація часу.
I	Розкриття чужих записів	Пацієнт змінює ID у GET /records/{id} та отримує історію хвороби іншої людини через відсутню об’єктну авторизацію - BOLA [2].	Перевіряти доступ до конкретного об’єкта на кожному запиті, включно з пошуком і експортом; фільтрувати поля відповіді; негативні тести між акаунтами. UUID не замінює перевірку прав.
D	Виснаження ресурсів API	Масові запити до пошуку без пагінації займають усі з’єднання з БД; лікарі не можуть відкрити записи.	Ліміти за користувачем та IP; пагінація і максимальний розмір відповіді; тайм-аути; ліміти паралельності; моніторинг і відокремлення важких операцій.
E	Підвищення привілеїв	Пацієнт викликає адміністративний endpoint зміни ролі, який прихований у клієнті, але не захищений на сервері.	Серверна перевірка ролі й дозволу на кожну функцію; заборона за замовчуванням; окрема процедура зміни ролей із повторною автентифікацією та аудитом.

Об’єктна авторизація відповідає на запитання «чи можна працювати саме з цим записом», а функціональна - «чи дозволена ця операція взагалі». Однієї перевірки входу або ролі недостатньо.

4 STRIDE аналіз бази даних

Об’єкт: база медичних записів разом із СУБД, службовими обліковими записами та підключеннями. Категорії S та E стосуються ідентичності й привілеїв доступу до СУБД, а не самих рядків таблиць.

Кат.	Загроза	Як проявляється	Захист
S	Підміна серверного компонента	Після витоку пароля БД із репозиторію сторонній процес підключається від імені API.	Сховище секретів і ротація; окремі облікові записи сервісів; мережеві обмеження; TLS із перевіркою сертифіката сервера; за можливості короткоживучі службові credentials.
T	Пошкодження клінічних даних	SQL-ін’єкція в незахищеному запиті дозволяє змінити інформацію про алергію або результати аналізів.	Параметризовані запити; мінімальні права облікового запису API; обмеження цілісності й транзакції; історія версій, сповіщення про аномальні зміни та перевірене відновлення.
R	Приховування змін у БД	Адміністратор вручну змінює результат аналізу та видаляє локальний журнал; неможливо встановити автора операції.	Іменні адміністративні акаунти; аудит СУБД та передавання подій у незалежне сховище з обмеженим видаленням; розділення ролей; контроль дій привілейованих користувачів.
I	Витік резервної копії	Резервна копія всієї БД стає доступною через помилково відкритий доступ до сховища.	Приватне сховище; мінімальні дозволи; шифрування БД і копій із окремим керуванням ключами; перевірка конфігурації доступу; маскування даних у тестових середовищах.
D	Втрата доступності БД	Скомпрометований привілейований акаунт використано для видалення таблиць і доступних йому резервних копій.	Незмінювані або офлайн-копії з окремими credentials; перевірки відновлення; реплікація для відмов обладнання; ізоляція мережі та обмеження привілеїв. Репліка не замінює резервної копії.
E	Надмірні привілеї сервісу	API працює як суперкористувач БД; після його компрометації атакувальник може видавати права й видаляти схему.	Окремі ролі читання, запису, експорту та міграцій; API без суперправ і права GRANT; адміністративний доступ лише через контрольований канал; регулярний перегляд дозволів.

Шифрування диска захищає викрадені носії, але не зупиняє читання через скомпрометований легітимний акаунт. Для цього потрібні контроль доступу, обмеження привілеїв і виявлення аномалій.

5 STRIDE аналіз сервісу експорту

Об’єкт: формування PDF, тимчасове зберігання, e-mail повідомлення та видача документа за посиланням. Експорт створює додаткову копію чутливих даних за межами основного інтерфейсу.

Кат.	Загроза	Як проявляється	Захист
S	Підміна ініціатора експорту	Сервіс довіряє user_id у повідомленні черги; сторонній виробник завдань указує ID лікаря та замовляє чужий PDF.	Автентифікація сервісів і права на чергу; приймати завдання лише від API; зв’язувати ініціатора із серверною сесією; перевіряти права повторно під час виконання.
T	Підміна вмісту PDF	Користувацький текст вставляється як необроблений HTML у шаблон і додає фальшивий діагноз або приховує частину висновку.	Екранування даних і контрольовані шаблони; медичні поля лише з авторитетного запису; незмінна версія джерела для експорту. Цифровий підпис за потреби виявляє зміни вже підписаного PDF.
R	Заперечення експорту	Працівник експортує багато історій хвороб, але журнал не фіксує, які записи були видані й кому.	Аудит ініціатора, ID та версій записів, одержувача, часу створення і завантаження, результату; захищений журнал. Не записувати діагнози, PDF або секретні токени в логи.
I	Витік через посилання	Постійне посилання без перевірки доступу пересилають іншій людині; вона завантажує медичний документ.	Приватне сховище; випадковий токен із коротким строком і можливістю відкликання; вхід та об’єктна авторизація під час завантаження; підтверджений одержувач; видалення тимчасових PDF.
D	Перевантаження генератора	Один акаунт замовляє тисячі великих PDF; черга заповнюється, пам’ять закінчується, експорти інших користувачів затримуються.	Квоти на користувача; межі кількості записів, розміру й часу генерації; обмежена черга та паралельність; окремі ресурси worker, щоб не зупиняти основне API.
E	Захоплення процесу генерації	Спеціально сформований вміст експлуатує вразливість PDF-рушія; атакувальник виконує код із правами worker.	Оновлений рушій; запуск без root у sandbox із мінімальними дозволами; файлова система переважно лише для читання; заборона довільної мережі й локальних файлів; відсутність адміністративних секретів.

Додаткова неочевидна загроза - SSRF: завантаження зовнішньої картинки PDF-рушієм може звернутися до внутрішнього сервісу. Потрібно заборонити довільні URL і мережевий вихід або дозволити лише перевірені ресурси. Відкликання посилання не видаляє вже завантажену копію.

6 П’ять найнебезпечніших загроз

STRIDE класифікує загрози, але не задає їхній пріоритет. Для цієї навчальної моделі оцінюю ризик до впровадження захистів: імовірність (I) та вплив (B) від 1 до 3; бал = I × B. 1 - низький, 2 - середній, 3 - високий рівень. Оцінки умовні, без статистики реальної клініки. За однакового бала пріоритет має можливість шкоди пацієнту або масового витоку.

STRIDE	Назва та ризик	Чому критична для СУМЗ	Пріоритетний захист
I	1. Доступ до чужих записів через API I3 × B3 = 9	Доступний звичайному користувачу сценарій може розкрити діагнози багатьох пацієнтів.	Об’єктна авторизація на кожному endpoint; фільтрація відповідей; тести доступу між пацієнтами.
T	2. Зміна клінічних даних I2 × B3 = 6	Підміна алергії, результату аналізу або призначення може вплинути на рішення лікаря.	Параметризовані запити; перевірка дозволів на поля; мінімальні права; версії та аудит змін.
D	3. Видалення БД і копій I2 × B3 = 6	Клініка втрачає доступ до історій хвороб; лікування й консультації можуть затриматися.	Окремі незмінювані копії; ізоляція адміністративного доступу; регулярне тестування відновлення.
S	4. Захоплення акаунта лікаря I2 × B3 = 6	Атакувальник отримує легітимні можливості перегляду, редагування й експорту в межах прав лікаря.	MFA; безпечні сесії; швидке відкликання; обмеження доступу до пацієнтів; виявлення аномалій.
I	5. Витік PDF за посиланням I3 × B2 = 6	Медична інформація потрапляє до сторонньої особи; завантажену копію неможливо надійно відкликати.	Автентифікація та перевірка прав при видачі; короткий строк посилання; перевірений одержувач; приватне сховище.

Топ-5 - пріоритет для цієї архітектури, а не універсальний рейтинг. Витік повної резервної копії або підвищення привілеїв також може мати максимальний вплив; після уточнення конфігурації їхній пріоритет може зрости. Запропоновані заходи знижують ризик, але не гарантують його повного усунення.

7 Висновок

Під час аналізу мене здивувало, що навіть успішний вхід у систему не означає безпечного доступу до даних. Якщо API перевіряє лише токен, але не право на конкретний медичний запис, звичайний пацієнт може отримати чужу історію хвороби. Тому перевірку доступу потрібно пов’язувати з кожним об’єктом і кожною операцією.

Неочевидними виявилися ризики експорту: PDF є окремою копією даних, посилання може потрапити сторонній особі, а сам генератор документів може звертатися до внутрішньої мережі. Також журнал аудиту потребує власного захисту: без нього важко встановити, хто змінив запис або завантажив документ.

STRIDE допоміг мені послідовно перевірити ідентичність, цілісність, підзвітність, конфіденційність, доступність і привілеї для кожного компонента. Для СУМЗ важливо захищати не лише таємницю діагнозу, а й достовірність даних, на основі яких лікар приймає рішення. Першими я б реалізував об’єктну авторизацію, захист облікових записів персоналу, аудит змін і перевірене відновлення з резервних копій.

Пояснення категорій

Код	Категорія	Що порушується
S	Spoofing - підміна особи	Автентичність користувача або сервісу
T	Tampering - несанкціонована зміна	Цілісність даних
R	Repudiation - заперечення дій	Можливість довести та відстежити дію
I	Information Disclosure - розголошення	Конфіденційність даних
D	Denial of Service - відмова в обслуговуванні	Доступність системи
E	Elevation of Privilege - підвищення привілеїв	Межі дозволених повноважень

Один сценарій може належати до кількох категорій: наприклад, викрадена сесія (S) може призвести до витоку (I) та зміни запису (T). У таблицях указана основна категорія кожного сценарію.

Джерела

[1] Microsoft Learn. Threats - Microsoft Threat Modeling Tool. Визначення категорій STRIDE. https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats

[2] OWASP. API1:2023 Broken Object Level Authorization. Принцип перевірки прав на кожен об’єкт API. https://api-security.owasp.org/editions/2023/en/0xa1-broken-object-level-authorization/

Архітектура, сценарії та оцінки ризику розроблені для цього навчального завдання; джерела використані для методології та пояснення BOLA.